ONE-PAGE BRIEF

Post-quantum cryptography review: nitro @ ccc5c828d9ea

Client: Offchain Labs (Arbitrum) — public repository (passive review) · Source: github.com/OffchainLabs/nitro, commit `ccc5c828d9ea` · Reviewed: 2026-10-28 18:10 UTC · Risk profile: Web3 project

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

1 Critical **8** High **18** Medium **24** Low **19** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Signatures: 10 + 5 − 12 = 3 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Critical QSI-2026-05596	**wee_alloc 0.4.5: informational advisory GHSA-rc23-xxgq-x27g (RUSTSEC-2022-0054) (unmaintained)** What to do: Plan a move to a maintained alternative, or record the decision to keep it.
High QSI-2026-05550	**TLS certificate verification disabled in arbnode/dataposter/config/config.go** What to do: Remove the override; use a proper CA bundle or pinning.
High QSI-2026-05614	**github.com/ethereum/go-ethereum v1.16.2 is affected by GHSA-mq3p-rrmp-79jg (CVE-2026-22868…** What to do: Upgrade to a fixed version (1.16.8).
High QSI-2026-05615	**github.com/ethereum/go-ethereum v1.16.2 is affected by GHSA-mr7q-c9w9-wh4h (CVE-2026-22862…** What to do: Upgrade to a fixed version (1.16.8).

47 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	ECDSA, Ed25519	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum…
Medium authentication and identity (certificates, tokens, device attestation)	Ed25519	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them
Medium role not determined	ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)…

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 51; unlikely to apply to this build: 12 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 39.

Static review of source code and manifests; files analysed: 1038. No requests were sent to the owner's systems.

Full report, content SHA-256: `bef977ec125421b714625439bc8fe3108a1e36383f7644d7a141aacbdc8ff184`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.